AI GRID

Strategy and Roadmap

Independent AI exposure and assurance for the bank's AI estate

1-YEAR ROADMAP Q4 2026 – Q3 2027
3-YEAR ROADMAP TO Q3 2029

AI Grid doesn't replace your AI Map, it keeps it honest.

SEPTEMBER 2026

About this plan

This plan merges AI security market research, the bank's AI strategy and the gaps found in a detailed review of that strategy into one plan, built around the bank's needs and timeline. Compared with the earlier research-based roadmap, it changes the plan in three ways:

- **Brought forward:** model security, deployment inside the bank's own environment, identity verification, telemetry ingestion, risk signals for the bank's policy engine, and mapping of agent-to-agent (A2A) delegation.
- **Added:** reconciling AI Grid's findings against the bank's own registries, checking the bank's asset cards and approved scopes against reality, an autonomy readiness gate, a registration gate in the build pipeline, and approval cycle-time metrics.
- **Deferred:** broader connector coverage (GCP and the long tail of SaaS) and AI Grid keeping its own asset register, since AI Grid now reconciles against the bank's.

01 The strategy

AI Grid is the independent exposure and assurance layer for the bank's AI estate. The bank is building its own "mesh" of gateways, identity, guardrails, telemetry and registries. AI Grid does four jobs that mesh can't do for itself:

- **Find** every AI asset, inside and outside the mesh.
- **Verify** that the mesh's declarations and controls hold in practice.
- **Feed** risk signals into the controls the bank owns.
- **Prove** all of this to risk, audit and regulators.

> *AI Grid doesn't replace your AI Map, it keeps it honest.*

WHY THE BANK SHOULD BUY RATHER THAN BUILD

- **Independence.** A second line of defence that grades the platform using the platform's own registry and telemetry isn't independent.
- **Coverage.** SaaS-native agents, end-user tools, developer tooling and models pulled from public hubs sit outside the mesh and outside the platform team's core work.
- **Time.** The strategy made the "secure and vigilant AI estate" critical by 2026, and the platform is still at MVP.
- **An open buying window.** The bank's own roadmap runs a model-discovery tool selection through 2026.

None of this touches what the strategy says can't be outsourced: values, orchestration, and controls tuned to its risk appetite. AI Grid plugs into those through open standards.

WHAT AI GRID WON'T BUILD

Gateways, guardrails, agent identity issuance, the registry or marketplace, orchestration, cost management, values checks or chat surveillance. AI Grid integrates with all of them.

OPERATING PRINCIPLES

- **Discovery first.** Nothing downstream works without a complete inventory.
- **Inside the bank's boundary by default.** No model weights, prompts or data leave the bank.
- **The bank's schema, not AI Grid's.** Findings use the bank's asset cards, approved scopes and asset classes.
- **Open standards.** OpenTelemetry (OTEL), CycloneDX ML-BOM and SPDX, OPA and Cedar policy data, MCP and A2A, in-toto and Sigstore.
- **An AI-native risk model.** AI assets aren't forced into the CVE/vulnerability model.
- **Conservative exposure scoring.** Runtime and probabilistic signals sit in a separate behavioural channel and never lower a static exposure score.

- **Runtime governance kept separate from static assessment.**
- **Read-only discovery.** Any action is executed through the bank's own controls.
- **Evidence over findings.** Every finding shows the path that creates the exposure and maps to a control.

02 How AI Grid meets the bank's needs

Bank need (from its strategy)	AI Grid capability	When
A complete Enterprise AI Map; detection of "grey AI" (unregistered assets)	Discovery across code, cloud, SaaS and endpoints, reconciled against the bank's registries and CMDB into unregistered, stale and drifted assets	Phase 1
Full scanning, inspection and auditability of every model; end-to-end model security (2026 H2)	Model scanning inside the bank's boundary, signature checks, reconciliation with the approved-model list	Phase 1
Sovereign, air-gapped operation with no data leaving	Collectors and scanners running inside the boundary; a control plane the bank can host itself	Phase 1; generally available (GA) in Phase 4
GitLab as the source of truth for models, tools, routing, guardrails, policies and agents	Scanning of code and of the control configuration stored there, including gaps in guardrails and policies	Phase 1
The agent identity standard (one Entra Agent ID per instance, ownership, exemptions)	Identity conformance checks, exemption tracking, detection of orphaned identities	Phase 2
Asset cards, approved scope and information barriers between legal entities	Declared-versus-observed verification; findings for out-of-scope connections and paths that cross legal entities	Phase 2
AI security control centre, SIEM, ITSM and CMDB	ServiceNow, Microsoft Sentinel and AI Map integrations	Phase 2
Autonomy only as identity, authorisation and action evaluation mature	Autonomy readiness gate	Phase 3
Security monitoring and rogue-agent discovery on shared telemetry	AI Grid as a security destination on the bank's OTEL pipeline (behavioural channel)	Phase 3 preview; Year 2 GA
Policy-driven routing based on attributes owned by the risk functions	Risk attributes published for the bank's OPA and Cedar policy engines	Phase 3
Mesh and A2A capabilities critical by 2027	A2A registry ingestion and delegation topology	Phase 3
Faster, consistent approvals ("minutes not months")	Evidence mapped to frameworks; checks that solutions conform to pre-approved patterns, for fast-track	Phases 3–4
Automated registration with software bills of materials (SBOMs) and integrity checks on third-party agents	Registration gate in the build pipeline; integrity monitoring of MCP servers and third-party agents	Phase 4
End-to-end model lineage (2027 H1)	Model lineage from source hub to the agents that use each model	Phase 4
EU AI Act and DORA evidence	Annex III high-risk workflow; AI supply-chain register	Phases 3–4
Misuse detection on every action; autonomous quarantine	Behavioural detection, verification of on-behalf-of identity chains, isolation through the bank's controls	Year 2
Organisation-wide agent memory; long-running plans	Security for memory stores and long-running plans	Year 2
Continuous attestation, signed provenance, regulator-ready lineage	Signed attestations per asset; lineage from decision to outcome	Years 2–3
Agent traffic with other organisations; external AI clients	Trust posture for external agents	Year 3

03 Keeping pace with the bank's timeline

Bank timeline	What the bank is doing	What AI Grid has in place
Late 2026: AI as assistant; MVP moving to the "Scalable Mesh" stage	Model-discovery tool selection; end-to-end model security; hackathons on autonomous operations and regulated workloads	Discovery inside the boundary, model security, grey AI detection, scanning of control configuration (Phase 1)
2027: complex AI ecosystems; mesh and orchestration critical; EU AI Act high-risk obligations from December	A2A through the gateway; model lineage; autonomous agents spreading before the "Adaptive" stage controls exist	Identity and scope verification, autonomy gate, telemetry detection, policy signals, pipeline gate, lineage and evidence (Phases 2–4)
2028: AI as coordinator; "Adaptive Mesh" stage	Long-running workflows; misuse detection and quarantine; organisation-wide memory; automated registration	Identity-chain verification, behavioural detection, isolation through the bank's controls, memory security, continuous attestation (Year 2)
2029 onward: AI as the worker, towards the autonomous enterprise	Signed provenance; continuous assurance; agents working across organisations	Continuous autonomy governance, regulator-ready lineage, external agent trust (Year 3)

04 1-year roadmap (Q4 2026 – Q3 2027)

Phase 1 — Land (Oct–Dec 2026): see the whole estate, inside the boundary

The goal is to win the pilot during the bank's model-discovery tool selection, running entirely inside its boundary.

#	Roadmap item	Bank need	Definition of Done
1.1	Pilot-ready standalone product: separated from the parent platform, demo mocks replaced by live data, product security baseline in place	Passing the bank's third-party risk review	No runtime dependency on the parent platform (dependency scan); every shipped view on live data; threat model reviewed; no critical/high static or dependency scan findings open more than 14 days; SBOM per release; external penetration test booked
1.2	Collectors and scanners that run on the bank's own Kubernetes (AWS, Azure or on-prem), sending only metadata to a single-tenant control plane in the bank's region	Sovereignty; zero data exposure; air-gapped operation	Installs in under a day; egress test shows only opted-in metadata leaves; model scanning runs fully air-gapped
1.3	Model supply-chain security: ModelScan across the Hugging Face Enterprise mirror, model buckets and vLLM-served models; signature verification; reconciliation with the approved-model list	Full scanning of every model; end-to-end model security; the tool selection	100% detection on a known-malicious model set; under 5% false positives on a benign set; every served model matched to an approved entry or flagged; results exportable to the model registry and model risk
1.4	Discovery across GitLab (self-managed) and GitHub: agent and MCP tool code, MCP configs, model references, and the bank's deployment repos	Grey AI in developer tooling; guardrails, policies and routing all deployed from GitLab	5,000 repos scanned in under 4 hours; precision ≥95% and recall ≥90% on a labelled benchmark; all six deployment artefact types discovered; routes with no guardrail config flagged; policy rules granting wildcard model or tool access flagged; rescan on every merge
1.5	Azure discovery switched back on (AI Foundry, Azure OpenAI, agents on AKS) with least-privilege, read-only access	A primary hosting estate	Read-only permissions published; tested on 3 subscriptions with more than 200 AI resources; zero write calls in audit logs
1.6	Registry reconciliation v1: the bank's agent, MCP server, model, crew and prompt registries plus the CMDB, compared against what AI Grid discovers	A complete Enterprise AI Map; grey AI detection	All five registry types reconciled; unregistered, stale and drifted assets reported in the bank's card format; likely owner identified for ≥80% of unregistered assets; weekly change report accepted by the platform team

PHASE 1 EXIT CRITERIA

- Pilot live inside the bank's boundary, covering the model estate and the agents and tools built in the 2026 hackathons.
- First grey-AI and model-security report delivered to the security control centre and the platform team.
- Third-party risk review passed with no critical gaps.
- Signed pilot agreement with written success criteria, and sponsors in both security and the AI platform team.
- Shortlisted in the model-discovery tool selection.

Phase 2 — Production (Jan–Mar 2027): verify identity and scope

The goal is to convert the pilot to production. That means verifying the two things the bank's strategy leans on hardest: its agent identity standard, and its declared asset cards and approved scopes.

#	Roadmap item	Bank need	Definition of Done
2.1	Enterprise-grade platform: single sign-on through Entra, SCIM provisioning, role-based access by persona, tamper-evident audit log, per-tenant encryption keys, UK/EU data residency, disaster recovery	Procurement and third-party risk	Access removed within 5 minutes of deprovisioning; every state-changing action logged in a hash chain; restore tested (back up within 4 hours, under 1 hour of data lost); SOC 2 Type I issued; penetration test closed with no open critical/high findings
2.2	AWS and Microsoft 365 coverage: Bedrock, AgentCore, agents and inference on EKS; Copilot Studio and M365 agents	Grey AI in low-code agents; the platform's primary cloud	Read-only permission manifests published; Copilot Studio agents discovered with owner, connectors and data sources; ≥95% of agents linked to their hosting identity
2.3	Agent identity conformance, read from Entra through the Graph API. Checks: one identity per agent instance; owner, IT-service and registration links present; intelligent tools on Entra Agent ID rather than service principals; no static keys; broad permissions only with a live exemption; no identities left orphaned after de-provisioning	The bank's agent identity standard	≥95% of identities matched to discovered agents; each rule of the standard implemented as a named check with evidence; alerts before exemptions expire; orphans flagged within 24 hours
2.4	Card and approved-scope verification: the bank's asset classes (approved scope, clients, agents, tools, MCP tools, hosting, applications, end-user tools with AI, models) modelled as first-class entities; declared versus observed residency, data classification, legal entity and authentication method	Asset cards; approved scope; information barriers	Every card field in the bank's specification mapped; findings for out-of-scope connections, residency mismatches and paths that cross legal entities, each with the path shown; false positives ≤10% after review with the bank's risk team
2.5	Exposure graph v1 with conservative scoring: agent or client → identity → tool or MCP server → data and applications, with blast radius	A CISO-level exposure view; board reporting	50,000 nodes and 250,000 edges queried in under 2 seconds (95th percentile); every score shows a readable path; no probabilistic inputs in the exposure score (unit-tested)
2.6	Integrations with the bank's working tools: ServiceNow (tickets and CMDB reconciliation), Microsoft Sentinel, the AI Map (unregistered assets written back as draft registrations), comments on GitLab merge requests	AI security control centre; lower-friction registration	Two-way ticket sync; ticket raised within 5 minutes of a finding; draft registrations at least 70% pre-filled

PHASE 2 EXIT CRITERIA

- First paid production contract.
- 30 days in production with no severity-1 incident.
- Identity and scope reports adopted by the security control centre as a regular input.

Phase 3 — Scale with autonomy (Apr–Jun 2027): gate autonomy on evidence

The goal is to be in place as the bank's mesh and orchestration become critical and autonomous agents spread, and to become the security consumer of its telemetry.

#	Roadmap item	Bank need	Definition of Done
3.1	Autonomy readiness gate: for each agent, checks the preconditions the bank's strategy sets for autonomy, across its three operating modes (human-consumed, human-observed, fully autonomous). Preconditions: identity conformance, no broad exemptions, telemetry with trace IDs, evaluation coverage, circuit breaker and rollback, approved scope, a way to isolate it	"Autonomy follows identity, authorisation and action evaluation"; the autonomous-operations templates	100% of human-observed and fully autonomous agents assessed; each precondition a named, testable check; pass/fail with reasons that the bank's helper agent and approval flow can consume
3.2	AI Grid as a security destination on the bank's OTEL pipeline (preview). It subscribes to the shared telemetry exporters and detects: breaks in the identity chain (missing actor claims, tokens not scoped to their audience, SAML used inside the mesh), unregistered agent IDs, tool calls outside approved scope, and unusual data egress. Alerts go to Sentinel	Security monitoring and rogue-agent discovery, which the bank's telemetry design still leaves undefined	Keeps up with pilot volume (e.g. 5,000 events/second); 100% detection on seeded identity-chain-break tests; alert precision ≥80% over 30 days; behavioural channel never changes exposure scores (tested)
3.3	Risk attributes for the bank's policy engine: exposure tier, open critical findings, identity conformance, scope drift and autonomy status for each node, published as OPA bundles and Cedar entity data	Policy-driven routing based on risk-owned attributes	Refreshed at least every 15 minutes; versioned schema; tested with OPA and Cedar in the bank's gateway pattern; AI Grid has no write access to enforcement points
3.4	A2A and multi-agent topology: ingest the A2A registry and agent cards; map delegation from orchestrator to sub-agent to tool for agent teams and swarms; flag connections to external organisations	Mesh and A2A critical by 2027	A2A registry fully reconciled; delegation depth and fan-out calculated for each orchestrator; every connection that crosses an external boundary flagged
3.5	Evidence packs v1: findings mapped to OWASP LLM and Agentic Top 10, MITRE ATLAS, NIST AI RMF, ISO/IEC 42001, EU AI Act articles, DORA third-party requirements and the bank's own standards; export to model risk (ValidMind) and GRC	"What did the agent do, why, what data, who authorised it"; faster approvals	Every finding type mapped; one-click export; accepted by the bank's model risk or audit function; baseline approval cycle time measured with the bank
3.6	Coverage expansion: Salesforce Agentforce, ServiceNow Now Assist, Databricks, Snowflake; MCP and IDE agent configs on developer machines, via endpoint-management feeds	Grey AI across SaaS and inconsistent developer tooling	Each connector has a permission manifest, tests and a coverage matrix; changes to MCP configs on developer machines detected within 24 hours

PHASE 3 EXIT CRITERIA

- Autonomy gate used in at least one real approval decision.
- Telemetry detection live on the bank's pipeline.
- A second production customer, or a second business unit at the bank.

Phase 4 — Continuous assurance (Jul–Sep 2027): ready for regulation and the Adaptive Mesh stage

The goal is to move from periodic scans to continuous checks, ahead of EU AI Act high-risk obligations in December 2027 and the bank's move to automated registration.

#	Roadmap item	Bank need	Definition of Done
4.1	Registration gate: a GitLab pipeline step that runs the registration security checklist automatically (manifest, SBOM and CycloneDX ML-BOM, model scan, identity and card checks)	A registration security checklist with a minimal SBOM, then automated registration from the build pipeline	Median run under 5 minutes; warns or blocks depending on policy mode; used by at least 10 hackathon teams
4.2	Continuous integrity checks on MCP servers and third-party agents: fingerprinting tool descriptions and schemas to catch "rug pulls" (tools that silently change behaviour after approval) and tool poisoning; version drift; mapping to known CVEs; richer MCP server cards	Integrity checks on third-party agents; MCP servers have the thinnest card in the bank's model	Description changes detected within 1 hour; CVE mapping for the main MCP server frameworks; MCP server cards filled out with the tools exposed, authentication method and data reach
4.3	Model lineage v1: source hub → internal mirror → fine-tune → deployment → endpoint → agents using the model	End-to-end model lineage (bank roadmap, 2027 H1)	Lineage for 100% of served models in scope; signed provenance recorded where available
4.4	Faster governance: verify that deployed solutions match the bank's pre-approved patterns and starter kits, as evidence for fast-track approval	The bank's top blockers: slow and inconsistent approvals	Conformance checks for the five most-used starter kits; at least 30% shorter approval cycle for fast-tracked solutions, measured with the bank
4.5	EU AI Act high-risk readiness: support for classifying Annex III systems, evidence of human oversight, checks on log retention	High-risk obligations from 2 December 2027	Evidence used in at least one internal audit or regulatory submission before December 2027
4.6	Control plane the bank can host itself, generally available; assurance certifications and service levels	Sovereignty for the most sensitive estates	Installed in a customer-controlled environment in under a day; air-gapped mode documented; SOC 2 Type II issued; ISO 27001 Stage 1 audit completed; 99.9% availability for 60 days

YEAR 1 SUCCESS METRICS

- At least three production customers, including the bank.
- SOC 2 Type II issued.
- Zero severity-1 security incidents in AI Grid itself.
- At the bank:
  - Grey AI falling quarter on quarter as a share of the estate.
  - Identity-standard conformance above an agreed threshold.
  - Registry records without drift above an agreed threshold.
  - A measured cut in approval cycle time for fast-tracked solutions.

05 3-year roadmap (to Q3 2029)

Year 2 (Q4 2027 – Q3 2028): runtime assurance for AI-coordinated work

#	Roadmap item	Bank need	Definition of Done
Y2.1	On-behalf-of identity chain verification, generally available. Rebuilds each chain of delegated authority across hops from telemetry and token metadata. Detects: breaks in the chain, token reuse, missing proof of possession, tokens used outside their audience, misuse of just-in-time privileged identities, and “confused deputy” paths (an agent tricked into using its own authority for someone else)	Zero-trust identity propagation; dynamic least privilege	≥90% of actions that cross hops resolved to complete chains; chain-break detection precision ≥90%; changes to the IETF and MCP authorisation drafts absorbed in under 2 weeks
Y2.2	Behavioural detection, generally available: a baseline for each agent’s tool use, data access and destinations; signs of manipulation such as prompt injection arriving through tool outputs; stuck or anomalous long-running workflows	Misuse detection on every action crossing the mesh	Precision ≥80% over 60 days at 2 or more customers; every alert carries evidence and a confidence level; analyst feedback loop live
Y2.3	Isolation through the bank’s own controls: AI Grid recommends quarantine actions (disable an Entra Agent ID, block a route through OPA, remove an asset from the marketplace), executed through the bank’s security automation or ITSM. Human approval by default; pre-authorised playbooks optional	Autonomous quarantine with human escalation	3 enforcement integrations; every action reversible and audited; no standing write credentials held by AI Grid; median time from detection to isolation under 5 minutes for pre-authorised playbooks
Y2.4	Security for memory and long-running plans: inventory of memory stores from session memory up to organisation-wide memory; signs of memory poisoning; memory crossing scope or legal-entity boundaries; oversight of credentials held for long-running plans	Organisation-wide memory; credentials held in escrow for long-running plans	Memory stores discovered for the bank’s main agent frameworks; memory access across boundaries flagged; seeded poisoning tests detected
Y2.5	Agent assurance testing: tests before deployment and on a schedule against the OWASP Agentic Top 10 (ASI01–ASI10), run inside the bank’s boundary against its starter kits and pluggable into the pipeline gate; results kept separate from exposure scores	Test harnesses and evaluations for the bank’s starter kits	Test library covers all 10 categories; runs are reproducible; built into the pipelines of 5 or more teams
Y2.6	Continuous attestation v1: signed attestations for each asset (identity, scope, SBOM, scan results, gate status) in in-toto/Sigstore formats, which the bank’s registry checks when onboarding an asset	Continuous SBOM attestation; signed provenance	≥90% of marketplace assets carry a current attestation; registry verification in production
Y2.7	Scale and certifications: 2 million assets per tenant; graph-store decision carried out; ISO 27001 certified; ISO/IEC 42001 for AI Grid’s own AI features; GCP, Workday, Pega and SAP coverage	Enterprise-wide rollout; the remaining estates	Queries at 2 million assets under 3 seconds (95th percentile); certificates issued; connectors live

YEAR 2 EXIT CRITERIA

- Runtime assurance in production at the bank across at least two business units.
- No exposure-score regressions caused by probabilistic signals.
- 10–15 production customers, with net revenue retention above 120%.

Year 3 (Q4 2028 – Q3 2029): assurance for the autonomous enterprise

#	Roadmap item	Bank need	Definition of Done
Y3.1	Trust for agents across organisations: inventory of external agents and external AI clients; a trust posture for each counterparty in A2A flows such as account switching; third-party AI evidence for operational resilience	Agent ecosystems spanning organisations; third-party risk	Every connection across an external boundary inventoried and scored; evidence pack for each external counterparty
Y3.2	Simulation of cascading failures and blast radius across multi-agent estates (OWASP ASI07/ASI08)	Complex AI ecosystems at scale	Simulations validated against at least one tabletop exercise per customer
Y3.3	Autonomy governance at scale: the readiness gate runs continuously across thousands of agents and recommends downgrading an agent's autonomy when its supporting evidence lapses	AI as the worker, with humans at the edges	Continuous re-evaluation; downgrade recommended within 1 hour of evidence lapsing
Y3.4	Regulator-ready lineage: human intent → plan → actions → outcomes, joined across sources with signed evidence	The "Enterprise Intelligence" stage: signed rationales, full lineage, continuous assurance	Lineage reproducible for sampled decisions; accepted in a regulatory review
Y3.5	A bounded "guardian" agent: AI Grid's own triage and investigation agent, operating with minimal permissions under ISO/IEC 42001 governance	Analyst workload at scale	Triage time cut by at least 40% in measured trials; no autonomous action without policy pre-authorisation
Y3.6	Ecosystem and standards: a partner SDK for connectors; contributions to OWASP, CoSAI and the NIST agentic overlays	Open standards; no lock-in	20+ connectors, 5 or more built by partners; at least 2 accepted standards contributions

YEAR 3 SUCCESS METRICS

- 30–50 production customers.
- Recognition in the analyst categories for AI security platforms and agent governance.
- Net revenue retention above 125%.
- A decision on independent growth versus a strategic transaction.

06 Landing and expanding at the bank

Motion	When	Scope	Bank owner	Proof point
Land	Q4 2026	Model security and grey AI detection for the hackathon teams and the model estate, running inside the boundary	Security control centre; AI platform team	Grey-AI and model-security report; outcome of the tool selection
Expand	H1 2027	Identity conformance, card and scope drift, integrations	CISO organisation; identity team; AI platform	Identity-standard conformance rate; drift closed
Expand	H2 2027	Telemetry security destination, autonomy gate, evidence packs	Security monitoring; model risk; audit	Autonomy decisions backed by evidence; approval cycle time
Enterprise	2028 onward	Runtime assurance and continuous attestation across business units, then across organisations	CISO; risk control towers	Attestation coverage; acceptance by regulators

PRICING

- A platform fee plus tiers by the number of AI assets under management.
- An uplift for deployment inside the bank's boundary or hosted by the bank.
- Design-partner terms in exchange for acting as a reference and giving roadmap input.

07 Risks and decision points

Risk	Mitigation
A builder bank's "we'll build it" reflex	Stay out of what it calls non-outsourceable; position AI Grid as independent verification for the second line; plug into its schemas, telemetry and policy engine
Microsoft-native tools cover the Microsoft part of the estate	Win on neutrality across the whole estate (AWS, on-prem, SaaS, developer tools) and on verifying the bank's own standards
Dependence on the bank's platform maturity (telemetry, registries, Entra Agent ID rollout)	Discovery and model security work without any of them; each integration degrades gracefully if its source isn't ready
Overfitting to one bank	Keep at least one design partner that relies on platform-native agents rather than its own mesh; make the card and scope models configurable schemas
False positives from behavioural detection erode trust	Separate behavioural channel; precision thresholds before general availability; recommendation-only by default
AI Grid becomes a high-value target, since it holds a map of the whole AI estate	Deployment inside the boundary, read-only connectors, per-tenant keys, continuous penetration testing, bug bounty by Year 2

DECISION POINTS

- **November 2026:** pilot scope agreed with the bank.
- **Q1 2027:** whether PostgreSQL + JSONB can carry the Year 2 graph, or a graph layer is needed.
- **Q2 2027:** whether pre-authorised isolation playbooks ship in Year 2, or AI Grid stays recommendation-only.
- **Q3 2027:** whether customer-hosted deployment becomes the default for regulated buyers.
- **Q3 2028:** go/no-go on trust for agents across organisations.
- **Q3 2029:** capital strategy.

08 Capacity

Year 1 needs about 12–16 people, up from the earlier estimate of 10–14, because deployment inside the boundary and registry reconciliation add work. That breaks down as:

- 9–11 engineers covering platform and site reliability, connectors, graph and scoring, identity, model security, frontend, and product security;
- a product manager and a designer;
- two solutions engineers;
- part-time compliance support.

Year 2 grows to 25–30 people and Year 3 to 40–55. If Year 1 is capped at 10–14, move coverage expansion (3.6) and model lineage (4.3) into Year 2. Don't cut identity conformance, scope verification or deployment inside the boundary, since those are what the bank is buying.